

# SOC ANALYST LEVEL 1

## LECTURE 7: ALERT TRIAGE

Decision Making: To Close or To Escalate?

Author: Nader Anam | Duration: 3 Training Hours



# LEARNING OBJECTIVES



## Triage Mastery

Understand the methodology behind initial alert sorting and filtering.



## Sev vs Conf

Master the difference between potential impact (Severity) and evidence strength (Confidence).



## Initial Analysis

Learn to write professional reports that justify your final decision.

- > Differentiate between Alert & Incident.
- > Identify required evidence (IP, Hash, User).
- > Analyze Malware & PowerShell alerts.
- > Identify False Positives vs Benign TP.
- > Learn the "Escalation Path" for Tier 2.

# WHY THIS LECTURE MATTERS

The daily life of a SOC L1 analyst revolves around one core question:

## "WHAT DO I DO WITH THIS?"

- > Close it? Monitor it?
- > Is it a real attack or a glitch?
- > Investigate further or alert the seniors?

*Weak analysts guess. Professional analysts build decisions on **evidence** and **context**.*

### | Dashboard Visualization

- Displays data via charts, graphs, and heatmaps.
- Highlights critical updates and trends at a glance.

### | Alerting & Notifications

- Sends alerts for threats or anomalies.
- Customizable notifications based on specific needs.

### | Incident Management

- Tracks and prioritizes security incidents.
- Supports faster responses with automated actions.

### | Compliance Reporting

- Generates reports for frameworks like GDPR,

# WHAT IS ALERT TRIAGE?

"The systematic process of receiving, assessing, and prioritizing security signals to determine if they require action or closure."

## Rapid Sorting

Identifying the critical "needle" in the haystack of logs.

## Evidence Gathering

Collecting basic logs (Who, What, Where, When).

## Initial Decision

Filtering noise to ensure the team focuses on real threats.

# THE TRIAGE ANALOGY



## ER vs. SOC

In a hospital, doctors don't perform surgery on everyone immediately. They sort:

- > **Critical:** Immediate action required.
- > **Minor:** Can wait for later.
- > **Specialist:** Needs a surgeon (Tier 2).

In SOC, we ask: Which alert is dangerous? Which is false? Which needs Tier 2?

# TRIAGE != QUICK CLOSE

**A dangerous habit:** Closing an alert because you don't understand it.

Proper Triage requires:

- > Gathering evidence.
- > Reviewing the context.
- > Documenting the "Why".

**Rule:** Lack of understanding is not a reason for closure. It is a reason for investigation.

## CYBERSECURITY INCIDENT REPORT

Date of Report: \_\_\_\_\_, 20\_\_

### Incident Details

Date: \_\_\_\_\_

Time: \_\_\_\_\_ ☐ AM ☐ PM

Location: \_\_\_\_\_

Type of Incident: (Check all that apply)

☐ Phishing Email or Attempt

☐ Malware/Ransomware Detection

☐ Unauthorized Access

☐ Data Breach

☐ Denial of Service (DoS/DDoS) Attack

☐ Compromised Account Credentials

☐ Lost or Stolen Device

☐ System Misconfiguration

☐ Insider Threat or Suspicious Behavior

☐ Other: \_\_\_\_\_

Describe the incident:

---

---

---

How was the incident detected? (Check all that apply)

☐ Antivirus or Endpoint Detection

☐ Firewall Alert or SIEM System

☐ Reported by Employee/User

☐ External Notification

☐ Routine Audit or Monitoring

☐ Other: \_\_\_\_\_

### Actions Taken

Were steps taken to contain or mitigate the incident? ☐ Yes ☐ No

Describe the actions taken to contain the incident:

---

---

---

# | TRIAGE != ESCALATE ALL

Sending every alert to Tier 2 weakens the SOC:

- > Wastes senior analysts' time.
- > Reduces trust in L1 analysis.
- > Causes massive **Alert Fatigue**.

## YOUR MISSION:

Filter the noise. Only escalate when you have **evidence of suspicious/malicious activity**.

600 × 400

# ALERT VS INCIDENT



## ALERT

A signal that needs checking.

Ex: 20 Failed Logins.



## INCIDENT

A confirmed security event.

Ex: Failed Logins -> Successful Login -> Encoded PowerShell -  
> C2 Connection.

**Every Incident starts as an Alert, but not every Alert is an Incident.**

# PRACTICAL GOAL OF TRIAGE

After triage, you must be able to answer the **BIG 5**:

## WHO?

Username / Host / Source IP.

## WHAT?

PowerShell? Malware? Login?

## WHEN?

Timestamp / Duration.

## WHERE?

Destination IP / Domain.

## WHY?

Authorization / Severity / Context.

## DECISION?

Close or Escalate?

# ALERT LIFECYCLE



This systematic workflow ensures no critical evidence is missed.

# PHASE 3: EVIDENCE COLLECTION

## Types of IoCs

| Network-Based IOCs                                                                                                                                      | Host-Based IOCs                                                                                                                                       | Email-Based IOCs                                                                                                                                        |
|---------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------|
|  <b>Malicious IP Addresses</b><br>Known IP addresses used for attacks  |  <b>File Hashes</b><br>Hashes of known malicious files               |  <b>Suspicious Attachments</b><br>Malicious files attached to emails   |
|  <b>Domain Names</b><br>Domains linked to malicious activity           |  <b>Registry Changes</b><br>Suspicious modifications to the registry |  <b>Phishing Indicators</b><br>Signs of deceptive or fraudulent emails |
|  <b>Unusual Network Traffic</b><br>Anomalous patterns in network data |  <b>Unusual Processes</b><br>Unexpected or malicious processes      |  <b>Malicious Links</b><br>Links to harmful websites or downloads     |

### The Evidence Checklist:

- > **Network:** SRC IP, DST IP, Port, Domain.
- > **Endpoint:** File Hash, Process, Parent Process.
- > **Identity:** Username, Login Type, MFA status.
- > **Context:** Time, User role, Asset criticality.

# SEVERITY VS CONFIDENCE

## SEVERITY (Impact)

How much damage can this cause if it's real?

**Example:** Ransomware detected on Domain Controller =  
**CRITICAL.**

## CONFIDENCE (Certainty)

How sure are we that this is malicious activity?

**Example:** 1 connection to unknown IP = **LOW CONFIDENCE.**

# TRIAGE SCENARIO MATRIX

| Alert Example                | Severity | Confidence | Analysis Basis                        |
|------------------------------|----------|------------|---------------------------------------|
| Malware Blocked by EDR       | Medium   | High       | Threat is real, but action was taken. |
| New Country Login (MFA Pass) | Medium   | Low        | Could be authorized travel.           |
| Encoded PS from Word         | High     | High       | Clear malicious behavior chain.       |

# SEVERITY LEVELS GUIDE

## Low, Moderate and High Risk Meter Vector



- > **LOW:** Minor noise, single failed login, random block.
- > **MEDIUM:** Multiple failures, new logins, blocked files.
- > **HIGH:** Success after failure, lateral movement, malware execution.
- > **CRITICAL:** Data exfiltration, Ransomware, DC compromise.

# HIGH SEVERITY INDICATORS



## Successful Login

Login after 20+ failures from external IP.



## Malware Execution

Alert stating "Malware Allowed" or "Executed".



## Encoded PS

PowerShell -enc originating from MS Word.

High Severity alerts almost ALWAYS require escalation to Tier 2.

# | WHAT IS A FALSE POSITIVE?

An alert triggered by **non-malicious** activity that mimics a threat.

- > Authorized Vulnerability Scanner.
- > IT Admin using PowerShell for tasks.
- > Software updates reaching out to servers.
- > Internal pentest activity.

**Verdict:** Close with Documentation of Authorization.

600 × 400

# DRILL 1: FAILED LOGIN ATTEMPTS

## ALERT DETAILS

**User:** Khaled

**Source IP:** 185.20.40.9 (External)

**Failed Attempts:** 25

**Success After:** No

**MFA:** Enabled

## QUESTIONS:

- > Is this Brute Force?
- > What is the Severity?
- > What is the Confidence?
- > Close or Escalate?

# DRILL 1: SOLUTION

## Authentication



## VERDICT: SUSPICIOUS / MONITOR

**Severity:** Medium

**Confidence:** Medium

**Analysis:** 25 attempts from external IP. Possible brute force, but blocked by policy/MFA. No success detected.

**Action:** Monitor account, check for success later. Close if no further hits.

# DRILL 2: FAILED + SUCCESSFUL

**Alert:** 18 Failures -> 1 Success (RDP Login) | **User:** Finance.Manager | **Time:** 01:40 AM

## IDENTIFIED IoCs

- > Pattern of failure then success.
- > Sensitive account (Finance).
- > Unusual time (01:40 AM).
- > External Source IP.

## DECISION: ESCALATE

**Severity:** High

**Verdict:** Potential Account Compromise.

**Recommendation:** Reset password, revoke sessions, check MFA logs immediately.

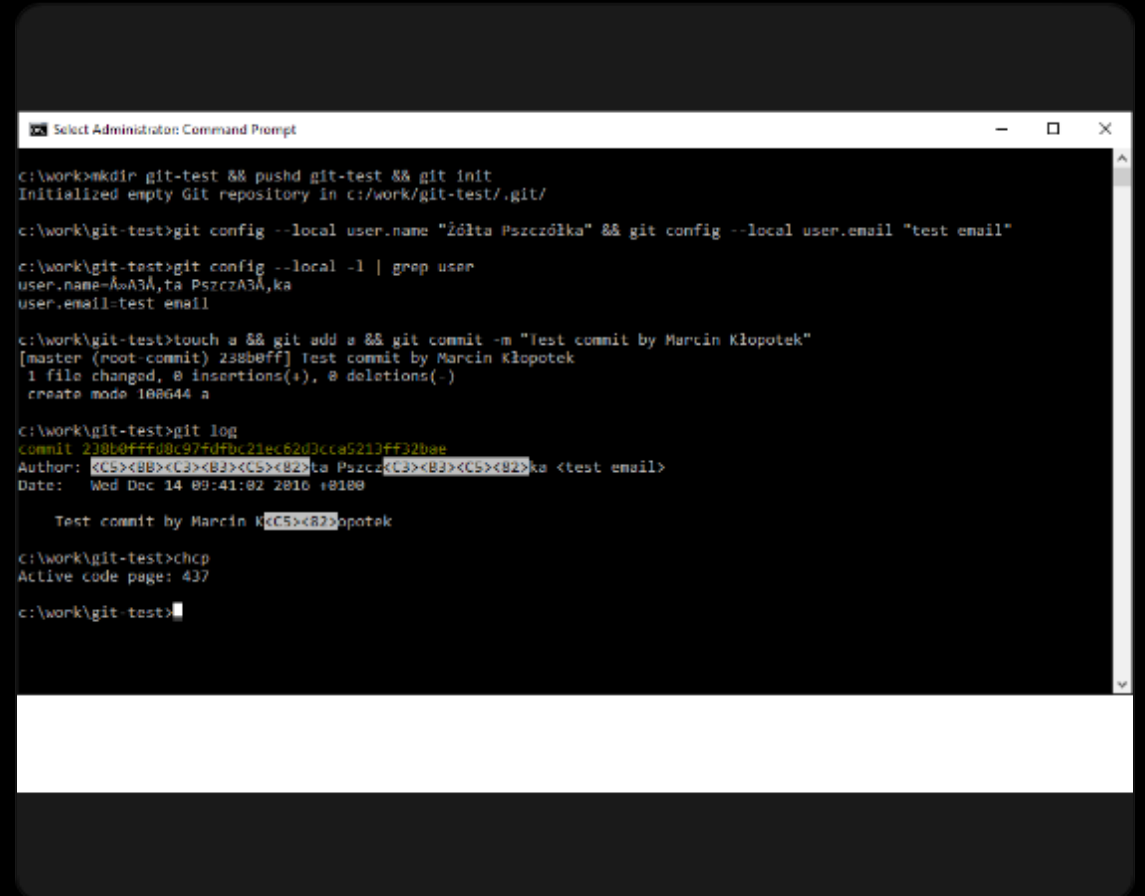
# DRILL 3: SUSPICIOUS POWERSHELL

**Command:** powershell.exe -enc aQBIAHgA...

**Parent:** winword.exe (MS Word)

**Network:** Connects to 91.200.10.5 every 60s.

**EDR:** Alerted but did not block.



```
Select Administrator: Command Prompt

c:\work>mkdir git-test && pushd git-test && git init
Initialized empty Git repository in c:/work/git-test/.git/

c:\work\git-test>git config --local user.name "Żółta Pszczółka" && git config --local user.email "test email"

c:\work\git-test>git config --local -l | grep user
user.name=Żółta Pszczółka,ka
user.email=test email

c:\work\git-test>touch a && git add a && git commit -m "Test commit by Marcin Kłopotek"
[master (root-commit) 238b0ff] Test commit by Marcin Kłopotek
1 file changed, 0 insertions(+), 0 deletions(-)
create mode 100644 a

c:\work\git-test>git log
commit 238b0ff00c97d4fbc21ec62d3cca5213ff32bae
Author: <C5><B3><C3><B3><C5><B2>ta Pszcz<C3><B3><C5><B2>ka <test email>
Date:   Wed Dec 14 09:41:02 2016 +0100

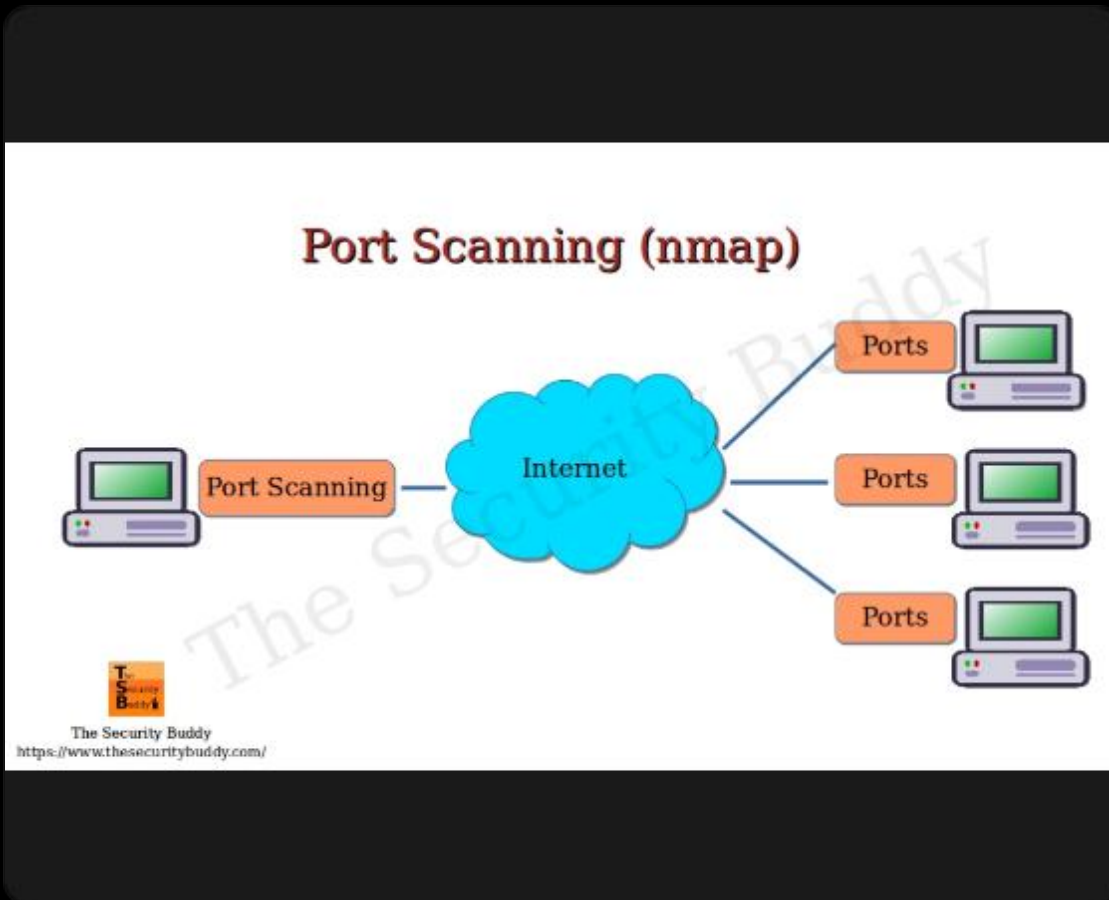
    Test commit by Marcin K<C5><B2>opotek

c:\work\git-test>chcp
Active code page: 437

c:\work\git-test>
```

**VERDICT: MALICIOUS BEACONING / ESCALATE TO TIER 2**

# DRILL 4: INTERNAL PORT SCAN



**Source:** 10.0.0.55

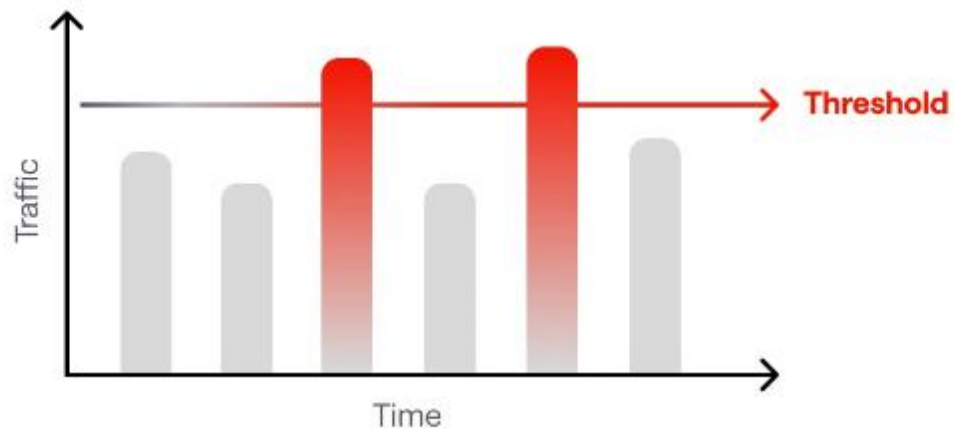
**Targets:** Entire subnet (254 hosts)

**Ports:** 22, 80, 443, 3389, 445

**INVESTIGATION NEEDED:**

- > Is 10.0.0.55 an IT Scanner?
- > Is there a scheduled scan today?
- > Did any logins follow this scan?

# DRILL 5: LARGE DATA TRANSFER



## CRITICAL ALERT

**Source:** FIN-PC-03 | **Volume:** 4.5 GB Outbound

**Destination:** 185.20.40.9 (External)

**Time:** 02:30 AM

**Previous Alert:** Suspicious Login detected 1 hour ago.

**VERDICT:** DATA EXFILTRATION IN PROGRESS. ESCALATE NOW.

# WRITING INITIAL ANALYSIS

## WEAK ANALYSIS

"This is very dangerous. I am escalating."

(No evidence, no context, unprofessional.)

## PROFESSIONAL ANALYSIS

"Alert shows 18 failed logins followed by a successful RDP login for a privileged user from an external IP at 01:40 AM. Pattern suggests account compromise. Escalating for Tier 2 verification."

# TOP ROOKIE MISTAKES

## Judging Titles

Closing alerts based only on the name without checking logs.

## Ignoring Context

Not asking "Is this normal for THIS user or THIS asset?"

## Bad Evidence

Escalating without including the IP, Hash, or Timestamp.

## Confusing Severity

Not understanding that a blocked threat can still be High Severity.

## Poor Phrasing

Using emotional language like "I'm scared" or "I think" instead of data.

## Missing "Success"

Failing to check if a brute force attempt eventually succeeded.

# | THE GOLDEN RULE OF TRIAGE

## DON'T JUST SAY IT. PROVE IT.

Instead of: "It's normal."

Say: "Closed as Benign TP; activity matched authorized IT scanner 10.0.0.55 during scheduled window."

Instead of: "It's hacked."

Say: "Escalating due to 22 failed logins followed by successful RDP and encoded PowerShell execution."

# | LECTURE SUMMARY

- > **Triage:** Filtering noise and prioritizing the real threats.
- > **Severity:** The potential damage. | **Confidence:** Strength of proof.
- > **False Positive:** Benign activity that looks malicious.
- > **Correlation:** Linking multiple alerts into a single attack story.
- > **Analysis:** Decisions must be documented with technical evidence.

**Triage is the HEART of SOC Level 1 operations.**

COMING UP NEXT

# LECTURE 8: PHISHING ANALYSIS

Sender verification, Header analysis, and Link inspection.



# IMAGE SOURCES



[https://cdn.prod.website-files.com/66f7129d03527383bf3191ea/6835f8e46d03c43ec6cf0ef5\\_SOC%20Dashboard-image.webp](https://cdn.prod.website-files.com/66f7129d03527383bf3191ea/6835f8e46d03c43ec6cf0ef5_SOC%20Dashboard-image.webp)

Source: [www.dropzone.ai](https://www.dropzone.ai)

---



<https://heimdalsecurity.com/blog/wp-content/uploads/2025/02/SIEM-Key-Features-min-1.jpg>

Source: [heimdalsecurity.com](https://heimdalsecurity.com)

---



[https://images.cartoonstock.com/lowres/families-lego-laceration-foot-emergency\\_room-hospital-CS613362\\_low.jpg](https://images.cartoonstock.com/lowres/families-lego-laceration-foot-emergency_room-hospital-CS613362_low.jpg)

Source: [www.cartoonstock.com](https://www.cartoonstock.com)

---



<https://legaltemplates.net/wp-content/uploads/Cybersecurity-Incident-Report-Form.webp>

Source: [legaltemplates.net](https://legaltemplates.net)

---



[https://www.paloaltonetworks.com/content/dam/pan/en\\_US/images/cyberpedia/indicators-of-compromise/types-of-iocs-comparison.jpg?imwidth=480](https://www.paloaltonetworks.com/content/dam/pan/en_US/images/cyberpedia/indicators-of-compromise/types-of-iocs-comparison.jpg?imwidth=480)

Source: [www.paloaltonetworks.com](https://www.paloaltonetworks.com)

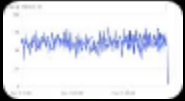
---



[https://www.slideteam.net/media/catalog/product/cache/1280x720/l/o/low\\_moderate\\_and\\_high\\_risk\\_meter\\_vector\\_Slide01.jpg](https://www.slideteam.net/media/catalog/product/cache/1280x720/l/o/low_moderate_and_high_risk_meter_vector_Slide01.jpg)

Source: [www.slideteam.net](https://www.slideteam.net)

# IMAGE SOURCES



<https://mintlify.s3.us-west-1.amazonaws.com/auth0/docs/images/cdy7uua7fh8z/6ywlqRG3zUAMwkAEGDoDoU/c24aa46d823ae702861ef57ee14dd9e6/Authentication.png>

Source: [auth0.com](https://auth0.com)

---



<https://i.sstatic.net/C3lKW.png>

Source: [stackoverflow.com](https://stackoverflow.com)

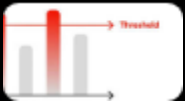
---



[https://www.thesecuritybuddy.com/wordpress/bdr/uploads/2020/02/Nmap\\_20.jpg](https://www.thesecuritybuddy.com/wordpress/bdr/uploads/2020/02/Nmap_20.jpg)

Source: [www.thesecuritybuddy.com](https://www.thesecuritybuddy.com)

---



<https://exeon.com/wp-content/uploads/2025/04/Data-exfiltration-Detection-graphic-Exeon-Analytics.webp>

Source: [exeon.com](https://exeon.com)

---



[https://www.mass.gov/files/styles/embedded\\_half\\_width/public/images/2025-09/phishing.png?itok=QnX4e0s1](https://www.mass.gov/files/styles/embedded_half_width/public/images/2025-09/phishing.png?itok=QnX4e0s1)

Source: [www.mass.gov](https://www.mass.gov)